

RATE-LIMIT BEHAVIOUR TESTING WITH FFUF

Repeated request testing, throttling observation, and abuse-control review

Field	Details
Module	Sub-Project 2 - API Security Testing Lab
Document Type	Individual API Security Methodology PDF
Phase / Test Case	Phase 6 - Rate-Limit Behaviour Testing
Prepared For	GitHub Portfolio Documentation
Prepared By	Jagriti Banerjee
Repository	Enterprise-Security-Assessment-Lab
GitHub Filename	06-rate-limit-behaviour-testing-methodology-report.pdf

This document is a professional, evidence-driven explanation of one API security methodology section. It is designed for portfolio review and contains only authorized lab-based testing context. Sensitive token values, account data, cookies, and private identifiers are redacted or intentionally represented with placeholders.

1. Section Overview

Area	Details
Phase	Phase 6 - Rate-Limit Behaviour Testing
Objective	Test how the API behaves under repeated requests and whether throttling, blocking, or 429-style responses are visible during controlled lab testing.
Primary Result	Evidence captured and methodology documented
GitHub Folder	02-api-security/reports/methodology/

Why this section matters

The evidence demonstrates rate-limit behaviour testing, not necessarily a confirmed absence of throttling unless the screenshot and request volume prove it. Professional reporting should avoid overclaiming and should describe exactly what the evidence supports.

2. Evidence Embedded in This PDF

Evidence 1: 08-no-rate-limiting-ffuf-running-p1.png

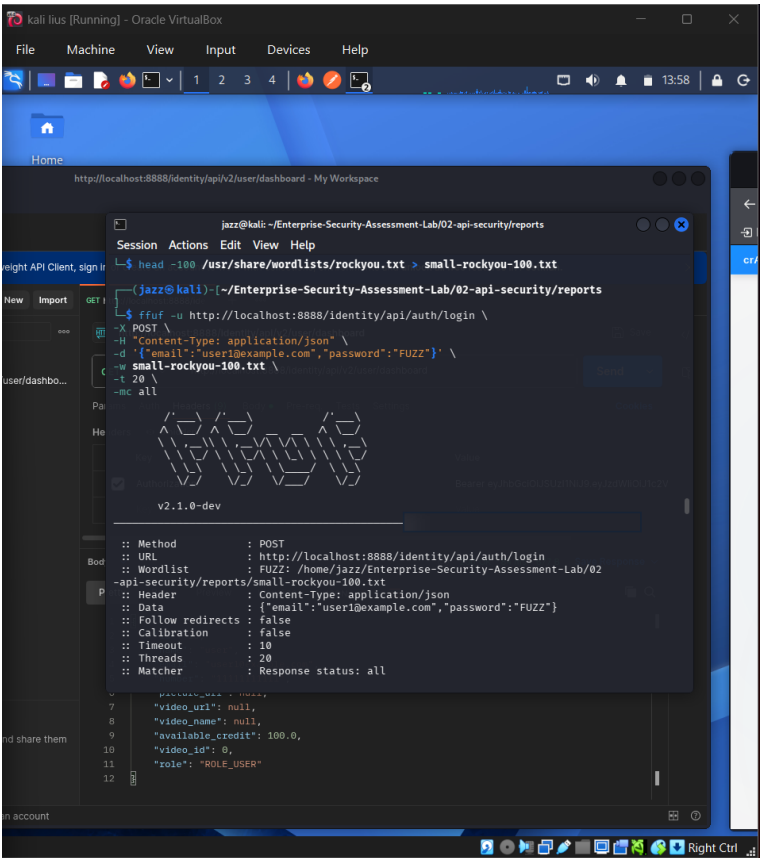


Figure 1 - ffuf evidence part 1 showing repeated request behaviour testing.

ffuf evidence part 1 showing repeated request behaviour testing.

Evidence 2: 08-no-rate-limiting-ffuf-running-p2.png

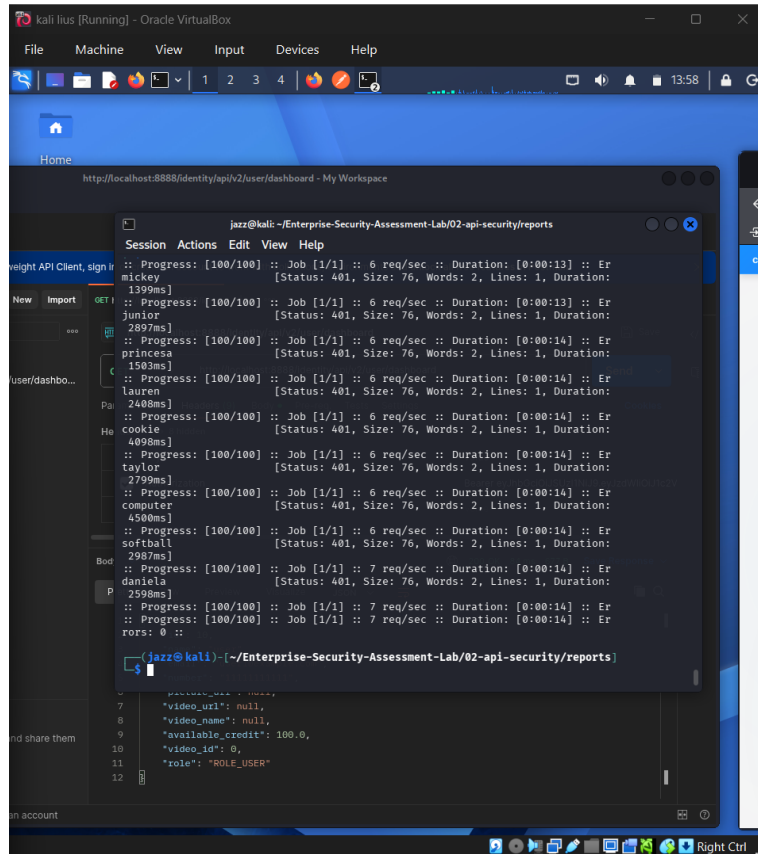


Figure 2 - ffuf evidence part 2 showing continued repeated request testing.

ffuf evidence part 2 showing continued repeated request testing.

3. Command and Workflow Used

```
ffuf \
-u http://127.0.0.1:8888/FUZZ \
-w /usr/share/wordlists/seclists/Discovery/Web-Content/api/api-endpoints.txt \
-t 20

# Professional reporting note:
# Report this as rate-limit behaviour testing unless evidence clearly proves
# that throttling was absent across a meaningful request volume.
```

Step-by-step workflow

- Selected a controlled lab endpoint or route pattern for repeated request testing.
- Executed ffuf with a bounded thread count against the local API target.
- Observed response codes, timing, and whether throttling behaviour was visible.
- Captured terminal evidence of the testing process.

4. Professional Interpretation

The evidence demonstrates rate-limit behaviour testing, not necessarily a confirmed absence of throttling unless the screenshot and request volume prove it. Professional reporting should avoid overclaiming and should describe exactly what the evidence supports.

5. Security Risk and Impact

Weak rate limiting can enable brute force, endpoint enumeration, credential stuffing, scraping, OTP abuse, coupon abuse, and resource exhaustion. APIs are especially exposed because clients can automate repeated requests easily.

6. Recommended Remediation and Hardening

- Implement endpoint-specific rate limits.
- Use user-based and IP-based throttling.
- Return 429 Too Many Requests when thresholds are exceeded.
- Protect login, password reset, OTP, search, and expensive query endpoints.
- Monitor repeated request patterns and alert on abnormal activity.
- Use abuse detection for credential stuffing and enumeration behaviour.

7. Framework Mapping

Framework Area	Mapping
OWASP API	API4: Unrestricted Resource Consumption
Security Control	Throttling, lockout, abuse monitoring
Evidence Result	Repeated request testing evidence

8. Sanitized Output Style for GitHub

When documenting this evidence publicly, use placeholders instead of live values. The goal is to prove methodology and security understanding without exposing secrets or private data.

```
Authorization: Bearer <REDACTED_TOKEN>
Cookie: <REDACTED_COOKIE>
email: lab-user@example.com
password: REDACTED
object_id: <CONTROLLED_LAB_ID>
redirect_uri: <REDACTED_OR_LAB_CALLBACK>
```

9. GitHub Redaction Checklist

- Bearer tokens and JWT values must be blurred or replaced with <REDACTED_TOKEN>.
- Email addresses, phone numbers, user IDs, and object identifiers should be blurred when they are not required for understanding the evidence.
- Authorization headers, cookies, session values, OAuth codes, refresh tokens, access tokens, and client secrets must never be visible in public GitHub screenshots.
- If a screenshot contains personally identifiable data, crop the view or blur the affected rows before publication.

10. Publication Note

This report is designed for GitHub portfolio use. It describes authorized lab testing only and avoids production claims. The embedded screenshots have been treated as lab evidence and should remain redacted before upload.